

PRODUCTION READINESS

Detailed Ticket Specification

Every backlog item written up as an actionable ticket — problem, impact, fix, acceptance criteria and technical notes — grouped by engineering workstream. Built for a colleague to pick up any ticket and start work without further context.

204

DETAILED TICKETS

17

WORKSTREAMS

23

P0 · BLOCKERS

DOCUMENT	Detailed Ticket Specification	GENERATED	03 June 2026
EACH TICKET	Problem · Impact · Fix · Acceptance · Notes	IDS	Match source backlog

How to read a ticket

Each ticket is a self-contained card. The five labelled fields tell you what's wrong, why it matters, what to do, how to know you're done, and where to look.

PROBLEM	The current, broken behaviour — stated concretely.
IMPACT	What it costs in security, money, compliance or reliability terms.
FIX	The concrete remediation to implement.
ACCEPTANCE	The testable condition that marks the ticket done.
NOTES	Technical hints and likely module/layer to touch (suggested, not prescriptive).

PRIORITY P0 launch blocker P1 soon after P2 hardening · EFFORT S <1 day M 1–3 days L 1–2 weeks

Workstreams

204 detailed tickets across 17 workstreams. Areas carrying launch-blocking (P0) work appear first.

CODE	WORKSTREAM	TOTAL	P0	P1	P2
COMP	Compliance & Business GST, payouts, KYC, RBI/PA-PG, consumer SLAs.	18	7	7	4
PAY	Payment Integrity Webhooks, idempotency, refunds, currency correctness.	11	4	4	3
AUTH	Authentication & Session OTP, tokens, sessions, refresh & logout.	18	2	8	8
PII	Data Security & PII Encryption, consent, erasure & DPDP Act 2023.	16	2	7	7
SEC	API Security OWASP, validation, uploads, CORS, rate limiting.	13	2	4	7
SHIP	Order Fulfillment & Logistics 3PL, tracking, returns/RMA, serviceability.	13	2	5	6
OPS	Observability & DevOps Containers, CI/CD, monitoring, backup & DR.	12	2	5	5
CACHE	Caching & Redis Strategy Cache strategy, stampede, revocation, observability.	13	1	4	8
AISVC	FastAPI AI Microservice LLM auth, abuse, spend caps, input/output validation.	12	1	4	7
FE	Frontend Security & UX Secure storage, SSL pinning, client-side integrity.	13	—	4	9
DB	Database Performance Indexing, pooling, pagination, query efficiency.	12	—	3	9
REV	Reviews & Moderation Verified purchase, moderation, spam & abuse.	12	—	6	6

Scalability & System Design

CODE	WORKSTREAM	TOTAL	P0	P1	P2
SCALE	Multi-process, queues, circuit breakers, sockets.	11	—	3	8
DS	Data Structures & Algorithms Algorithmic efficiency & in-memory vs DB work.	10	—	3	7
AUTHZ	Authorization, RBAC & IDOR Role checks, object-level access, privilege escalation.	7	—	1	6
CFG	Secrets & Configuration Secret storage, validation, rotation & revocation.	7	—	3	4
FRAUD	Fraud Detection Velocity, device fingerprinting, abuse signals.	6	—	3	3

Priority: P0 7 P1 7 P2 4

Effort: S 0 M 18 L 0

☐ COMP-1 P0 M Implement GST Invoice Generation & Tax Compliance

PROBLEM There is no GST invoice generation or tax-compliant billing.

IMPACT Sales lack legally required GST invoices — a compliance and accounting gap for an Indian marketplace.

FIX Generate GST-compliant invoices (GSTIN, HSN, tax breakup, sequential numbering) per order.

ACCEPTANCE Each completed order produces a compliant invoice retrievable by buyer and seller.

NOTES New invoicing service; depends on seller GSTIN (PII-9) and order totals.

☐ COMP-2 P0 M Add Seller Payout & Settlement System

PROBLEM There is no seller payout/settlement system.

IMPACT Sellers can't be paid out; funds flow and reconciliation are undefined.

FIX Implement settlement: compute net of fees/refunds, schedule payouts, record ledger entries.

ACCEPTANCE A completed sale results in a scheduled, auditable payout to the seller.

NOTES Payout service + ledger; pairs with COMP-17 bank verification, PAY ledger.

☐ COMP-3 P0 M Implement Razorpay Webhook Handler for Payment Confirmation

PROBLEM There is no Razorpay webhook handler; payment status is taken from the client.

IMPACT Payments can be spoofed/missed; server truth depends on the browser.

FIX Implement a signed webhook handler as the source of truth for payment state.

ACCEPTANCE Order is marked paid only on a verified webhook, not client claims.

NOTES Webhook endpoint with signature check; resolves PAY-1; see COMP-18 retries.

☐ COMP-4 P0 M Add Account Deletion & Right-to-Be-Forgotten (DPDP Act Compliance)

PROBLEM No account deletion / right-to-be-forgotten flow exists.

IMPACT Violates DPDP Act erasure obligations; users can't remove their data.

FIX Provide deletion that erases/anonymizes PII across stores with verification and audit.

ACCEPTANCE A deletion request removes/anonymizes the user's PII and is logged.

NOTES Implements PII-6; coordinate cascade across Prisma + Cloudinary + AI store.

☐ COMP-5 P0 M Implement Chargeback/Refund Abuse Detection & Prevention

PROBLEM No chargeback/refund-abuse detection or prevention.

IMPACT Serial refund/chargeback abuse causes direct financial loss.

FIX Track refund/chargeback velocity per user/device and flag/limit abusers.

ACCEPTANCE Repeat-abuse patterns are flagged and throttled.

NOTES Overlaps FRAUD-2; needs payment + order history.

COMP-6 P0 M Add Digital Proof-of-Delivery (POD) and Seller Authorization on Refunds

PROBLEM Refunds lack digital proof-of-delivery and seller authorization.

IMPACT Refunds can be issued without evidence or seller sign-off, enabling disputes/loss.

FIX Require POD capture and seller authorization in the refund workflow.

ACCEPTANCE A refund cannot complete without POD and seller approval where required.

NOTES Refund flow; ties to PAY-7/PAY-10 and SHIP POD.

COMP-7 P0 M Implement Admin Dashboard for Moderation, KYC, & Dispute Resolution

PROBLEM No admin dashboard for moderation, KYC, and dispute resolution.

IMPACT Operations can't moderate content, verify KYC, or resolve disputes at scale.

FIX Build an admin console covering moderation queue, KYC review, and dispute handling.

ACCEPTANCE Admins can action moderation/KYC/disputes from one authenticated console.

NOTES Depends on AUTH-10 admin auth, REV-5 queue, AUTHZ RBAC.

COMP-8 P1 M Add Return Merchandise Authorization (RMA) Workflow

PROBLEM No Return Merchandise Authorization (RMA) workflow.

IMPACT Returns are ad hoc; no structured authorization/tracking.

FIX Add an RMA flow: request, approve, return label/tracking, inspection, resolution.

ACCEPTANCE A return follows a tracked RMA lifecycle end to end.

NOTES Overlaps SHIP-6; shares state with refunds (PAY-7).

COMP-9 P1 M Implement Multi-Language Content Localization Beyond English/Hindi

PROBLEM Content localization is limited beyond English/Hindi.

IMPACT Excludes many regional-language farmers — adoption and accessibility gap.

FIX Introduce an i18n framework and add priority regional languages.

ACCEPTANCE UI/content render in the added languages; strings externalized.

NOTES Frontend i18n + content pipeline.

COMP-10 P1 M Add Velocity Checks & Device Fingerprinting for Fraud Prevention

PROBLEM No velocity checks or device fingerprinting for fraud prevention.

IMPACT High-velocity fraud and multi-account abuse go undetected.

FIX Add velocity rules and device fingerprinting signals into risk scoring.

ACCEPTANCE Abnormal velocity/devices raise risk flags on relevant actions.

NOTES Overlaps FRAUD-1/FRAUD-3.

□ **COMP-11** **P1** **M** **Document & Enforce RBI Payment Aggregator (PA-PG) Compliance**

PROBLEM RBI Payment Aggregator (PA-PG) compliance isn't documented or enforced.

IMPACT Operating payments without PA-PG alignment is a regulatory risk.

FIX Document the PA-PG posture, ensure funds-flow/settlement compliance, and enforce required controls.

ACCEPTANCE A compliance doc maps controls to PA-PG requirements; gaps tracked.

NOTES Works with COMP-2/COMP-3 settlement and webhook truth.

□ **COMP-12** **P1** **M** **Implement Inventory Hold-and-Release Window for COD Orders**

PROBLEM No inventory hold-and-release window for COD orders.

IMPACT Stock can be oversold or locked incorrectly for COD.

FIX Reserve stock on COD order with a timed release if unconfirmed/cancelled.

ACCEPTANCE COD orders hold stock and auto-release on timeout.

NOTES Overlaps SHIP-9; needs reservation state in inventory.

□ **COMP-13** **P1** **M** **Add Consumer Complaint Resolution SLA & Escalation**

PROBLEM No consumer-complaint resolution SLA or escalation path.

IMPACT Complaints may stall; no accountability — consumer-protection risk.

FIX Define SLAs, track timers, and auto-escalate breaches.

ACCEPTANCE Complaints show SLA timers and escalate on breach.

NOTES Support/dispute module; surfaces in admin (COMP-7).

□ **COMP-14** **P1** **M** **Implement Content Security Policy (CSP) Headers for XSS Prevention**

PROBLEM No Content-Security-Policy headers for XSS prevention.

IMPACT Injected scripts can run, especially risky with token storage issues.

FIX Add a strict CSP (and related security headers) to web responses.

ACCEPTANCE Responses carry CSP; inline/unauthorized scripts are blocked.

NOTES Web server headers; complements AUTH-9 secure storage.

□ **COMP-15** **P2** **M** **Add Accessibility (WCAG 2.1 AA) Compliance Testing & Fixes**

PROBLEM No accessibility (WCAG 2.1 AA) testing or fixes.

IMPACT Excludes users with disabilities; potential legal/UX gap.

FIX Run accessibility audits and remediate to AA (contrast, labels, focus, alt text).

ACCEPTANCE Key flows pass automated + manual AA checks.

NOTES Frontend; add a11y linting to CI (OPS-11).

☐ **COMP-16** **P2** **M** **Implement Data Retention & Automated Cleanup Policies**

PROBLEM No data-retention or automated-cleanup policies.

IMPACT Data is kept indefinitely — DPDP minimization and storage-cost issues.

FIX Define retention per data class and run automated purges.

ACCEPTANCE Data past retention is purged/anonymized on schedule.

NOTES Implements PII-8; reuse cleanup jobs (CACHE-8).

☐ **COMP-17** **P2** **M** **Add Bank Account Verification & Validation for Seller Payouts**

PROBLEM No bank-account verification/validation for seller payouts.

IMPACT Payouts may go to invalid/incorrect accounts; fraud risk.

FIX Validate IFSC/account (penny-drop or API) before enabling payouts.

ACCEPTANCE Payouts require a verified bank account.

NOTES Pairs with COMP-2 payouts and PII-3 bank-detail encryption.

☐ **COMP-18** **P2** **M** **Implement Webhook Delivery Logging & Retry Logic**

PROBLEM No webhook delivery logging or retry logic.

IMPACT Lost webhooks cause missed payment/state updates with no recovery.

FIX Log every webhook, verify, and retry failures with idempotent handling.

ACCEPTANCE Failed webhook processing retries and is fully logged.

NOTES Webhook handler (COMP-3); idempotency keys (PAY-2).

Priority: P0 4 P1 4 P2 3

Effort: S 6 M 5 L 0

☐ PAY-1 P0 M Client-Driven Payment Confirmation (No Webhook)

PROBLEM Payment confirmation is client-driven; there is no webhook source of truth.

IMPACT A malicious client can claim payment without paying.

FIX Confirm payments only via the signed Razorpay webhook.

ACCEPTANCE Orders move to paid only on a verified webhook.

NOTES Implemented by COMP-3 webhook handler.

☐ PAY-2 P0 M No Idempotency Key on Payment Confirm

PROBLEM Payment-confirm has no idempotency key.

IMPACT Retries/duplicates can double-process a payment or order.

FIX Require an idempotency key and dedupe confirm operations.

ACCEPTANCE Repeating a confirm with the same key is a no-op.

NOTES Payment service; store processed keys (Redis/DB). Pairs with PAY-5.

☐ PAY-3 P0 S No Amount Verification on Confirm

PROBLEM On confirm, the paid amount isn't verified against the order amount.

IMPACT Underpayment/tampering can be accepted.

FIX Verify the gateway amount equals the order amount before marking paid.

ACCEPTANCE Amount mismatches are rejected.

NOTES Confirm/webhook handler; ties to FRAUD-6.

☐ PAY-4 P0 S Mock Mode Silent Fallback in Production

PROBLEM Payment mock mode can silently fall back in production.

IMPACT Real orders may be 'paid' via mock with no money moving.

FIX Disable mock in production and fail loudly if invoked.

ACCEPTANCE Production never enters mock mode; misconfig errors out.

NOTES Payment config guard; overlaps SEC-5/SHIP-11/CFG-3.

☐ PAY-5 P1 S No Duplicate Payment Protection

PROBLEM No duplicate-payment protection.

IMPACT A user can be charged twice for one order.

FIX Detect and block duplicate charges per order (idempotency + state checks).

ACCEPTANCE A second charge for a paid order is prevented.

NOTES Builds on PAY-2 idempotency.

□ PAY-6 P1 M Missing Credit Purchase Endpoint

PROBLEM There is no credit-purchase endpoint (for AI credits).

IMPACT Users can't buy AI credits through a proper, auditable flow.

FIX Add a credit-purchase endpoint integrated with payments and an audit trail.

ACCEPTANCE A purchase increments credits and records a ledger entry.

NOTES Pairs with PAY-11 audit trail and AI spend tracking.

□ PAY-7 P1 M No Refund Workflow

PROBLEM There is no refund workflow.

IMPACT Refunds can't be processed cleanly; disputes escalate.

FIX Implement refunds: initiate via gateway, update order/ledger, notify parties.

ACCEPTANCE A refund completes end-to-end and is recorded.

NOTES Refund service; ties to COMP-6/COMP-8/SHIP-4.

□ PAY-8 P1 M Float-Based Currency in Database

PROBLEM Currency is stored as float in the database.

IMPACT Rounding errors corrupt financial records.

FIX Use integer minor units or Decimal for money.

ACCEPTANCE Money values round-trip without drift.

NOTES Schema migration; same as DB-7.

□ PAY-9 P2 S No Payment Method Traceability

PROBLEM No payment-method traceability on transactions.

IMPACT Hard to reconcile or investigate by method.

FIX Record method/instrument metadata per transaction.

ACCEPTANCE Each transaction stores its payment method.

NOTES Payment record schema.

□ PAY-10 P2 S Seller Refund Authorization Gap (Structural)

PROBLEM Structural gap: seller refund authorization isn't enforced.

IMPACT Refunds may bypass seller approval where it's required.

FIX Enforce seller authorization in the refund state machine.

ACCEPTANCE Refunds requiring seller approval can't complete without it.

NOTES Refund flow; overlaps COMP-6.

□ **PAY-11** **P2** **S** **No AI Credit Purchase Audit Trail**

PROBLEM	No audit trail for AI credit purchases.
IMPACT	Credit changes aren't traceable for billing/disputes.
FIX	Log all credit purchases/consumption with amounts and references.
ACCEPTANCE	Credit movements are fully auditable.
NOTES	Pairs with PAY-6; feeds audit (OPS-8).

Authentication & Session

AUTH

OTP, tokens, sessions, refresh & logout.

18
TICKETS

Priority: P0 2 P1 8 P2 8

Effort: S 4 M 11 L 3

☐ AUTH-1 P0 M OTP Rate Limiting Disabled — Critical for Production

- PROBLEM** The OTP-send endpoint has no rate limit, so unlimited OTPs can be requested for any number.
- IMPACT** Enables SMS-bombing, runs up SMS-gateway cost, and aids enumeration/brute force.
- FIX** Add per-phone and per-IP sliding-window limits (e.g. 5/hour/phone) backed by Redis.
- ACCEPTANCE** Exceeding the threshold returns 429 with retry-after; verified by test.
- NOTES** Express OTP-send route + shared rate-limit middleware; counters in Redis with TTL.

☐ AUTH-2 P0 M Global Rate Limiter Disabled

- PROBLEM** The global rate limiter exists but is disabled, leaving all routes unthrottled.
- IMPACT** No brute-force/DDoS protection; one client can saturate the API.
- FIX** Enable a global per-IP limiter with sane defaults and per-route overrides.
- ACCEPTANCE** Load test shows over-cap requests get 429; limiter active in prod config.
- NOTES** Express top-level middleware mounted before routers; Redis-backed store.

☐ AUTH-3 P1 S Profile Write Rate Limiting Disabled

- PROBLEM** Profile-write endpoints have rate limiting disabled.
- IMPACT** Allows rapid profile churn, abuse, and write amplification.
- FIX** Apply a modest write limit per user on profile-mutating routes.
- ACCEPTANCE** Burst writes beyond the cap return 429.
- NOTES** Profile router; same limiter middleware, per-user key.

☐ AUTH-4 P1 M No Account Lockout After OTP Brute-Force

- PROBLEM** There is no account lockout after repeated failed OTP verifications.
- IMPACT** Permits sustained OTP brute-force against a known number.
- FIX** Lock the account/number after N failed attempts with exponential backoff and notify the user.
- ACCEPTANCE** After N failures the account is temporarily locked; lock clears on timeout/verified reset.
- NOTES** OTP-verify handler; track failures in Redis keyed by phone.

☐ AUTH-5 P1 M Redis Rate Limiter Implementation is a No-Op

- PROBLEM** The Redis-backed rate limiter is implemented as a no-op (calls succeed without enforcing).
- IMPACT** Code appears protected but offers no actual limiting in production.
- FIX** Implement real atomic counters (INCR + EXPIRE or a token-bucket Lua script) and wire them in.
- ACCEPTANCE** Unit test proves counters increment and block; manual test returns 429.
- NOTES** Rate-limit utility module; replace stub with Redis ops.

□ AUTH-6 P1 M No Refresh Token Rotation on Every Access

PROBLEM Refresh tokens are not rotated on each access-token refresh.

IMPACT A leaked refresh token stays valid indefinitely, enabling silent long-term takeover.

FIX Issue a new refresh token on every use, invalidate the prior one, and detect reuse.

ACCEPTANCE Reusing an old refresh token after rotation is rejected and flags the session.

NOTES Token service; store refresh-token family/jti and revoke on rotation.

□ AUTH-7 P1 L No Device-Specific Session Management

PROBLEM There is no per-device session management; sessions aren't tracked or individually revocable.

IMPACT Users can't see or end sessions on lost devices; no targeted revocation.

FIX Record sessions with device metadata and add list/revoke endpoints.

ACCEPTANCE A user can list active devices and revoke one without affecting others.

NOTES Session store keyed by user+device; surface in account settings.

□ AUTH-8 P1 S No Token Invalidation on Profile/Phone Changes

PROBLEM Tokens are not invalidated when a profile or phone number changes.

IMPACT Old tokens remain valid after a security-relevant change, widening the attack window.

FIX Bump a per-user token version on sensitive changes and reject tokens with a stale version.

ACCEPTANCE After a phone change, previously issued tokens are rejected.

NOTES Add tokenVersion to the user record; check it in auth middleware.

□ AUTH-9 P1 L Frontend Web Uses sessionStorage, Not Secure Storage

PROBLEM The web frontend stores auth state in sessionStorage rather than secure storage.

IMPACT Tokens are readable by any injected/XSS script and lost/exposed inconsistently.

FIX Move to httpOnly secure cookies for tokens, or a hardened storage strategy with CSP.

ACCEPTANCE Tokens are not present in JS-readable storage; auth survives reload securely.

NOTES Web auth layer; pair with COMP-14 CSP and AUTH-12 CSRF.

□ AUTH-10 P1 L No Admin-Specific Authentication Routes

PROBLEM There are no admin-specific authentication routes; admin access isn't separated from user auth.

IMPACT No strong boundary or step-up for privileged operations.

FIX Add a dedicated admin auth path with stronger requirements (separate role, optional 2FA) and isolated routes.

ACCEPTANCE Admin endpoints require admin auth; normal users cannot reach them.

NOTES New admin router + role gate; ties into AUTHZ RBAC.

□ AUTH-11 P2 M Concurrent Session Limit Not Enforced

PROBLEM No limit on concurrent sessions per user.

IMPACT Credential sharing and token sprawl go unchecked.

FIX Cap concurrent sessions and evict the oldest when exceeded.

ACCEPTANCE Creating a session beyond the cap evicts the oldest.

NOTES Session store; enforce on login.

□ AUTH-12 P2 M No CSRF Protection on State-Changing Routes

PROBLEM State-changing routes lack CSRF protection.

IMPACT If cookie auth is used, cross-site requests can act as the user.

FIX Add CSRF tokens (double-submit or synchronizer) on mutating routes.

ACCEPTANCE Mutating requests without a valid CSRF token are rejected.

NOTES Express CSRF middleware; required once cookies are adopted (AUTH-9).

□ AUTH-13 P2 S Bearer Token Parsing Lacks Malformed Input Validation

PROBLEM Bearer-token parsing doesn't validate malformed input.

IMPACT Malformed headers may cause errors or inconsistent auth handling.

FIX Strictly parse the Authorization header and reject malformed tokens with 401.

ACCEPTANCE Garbage Authorization values return 401, not 500.

NOTES Auth middleware header parsing.

□ AUTH-14 P2 M OTP Verification Lacks Rate Limiting on Attempts

PROBLEM OTP verification attempts are not rate-limited.

IMPACT Allows rapid guessing of the OTP code itself.

FIX Limit verify attempts per code/number and expire codes quickly.

ACCEPTANCE Excess verify attempts return 429; code expires after short TTL.

NOTES OTP-verify route; complements AUTH-4 lockout.

□ AUTH-15 P2 M JWT Access Token Expiry is Very Long (7 days default)

PROBLEM JWT access tokens default to a very long 7-day expiry.

IMPACT A stolen access token is usable for a week.

FIX Shorten access-token TTL (e.g. 15–60 min) and rely on refresh rotation.

ACCEPTANCE Access tokens expire within the new short window.

NOTES Token config; pair with AUTH-6 rotation.

□ AUTH-16 P2 M No Session Timeout on Server

PROBLEM There is no server-side session timeout.

IMPACT Idle sessions never expire server-side.

FIX Add absolute and idle timeouts enforced on the server.

ACCEPTANCE Sessions idle beyond the timeout are invalidated.

NOTES Session store TTL + last-activity tracking.

□ AUTH-17 P2 S Frontend Refresh Token Stored in Memory, Vulnerable to Page Reload

PROBLEM The frontend keeps the refresh token only in memory, lost on page reload.

IMPACT Users are logged out on reload; encourages weaker storage workarounds.

FIX Use a secure persistent mechanism (httpOnly cookie) so refresh survives reload safely.

ACCEPTANCE Reloading the page keeps the user authenticated without exposing the token to JS.

NOTES Web auth; same direction as AUTH-9.

□ AUTH-18 P2 M No Audit Log for Authentication Events

PROBLEM Authentication events are not audit-logged.

IMPACT No trail for logins, failures, or token events — weakens incident response and compliance.

FIX Emit structured audit events for login, logout, OTP failure, and token rotation.

ACCEPTANCE Auth events appear in the audit log with actor, time, and outcome.

NOTES Audit-logging service; see OPS-8/SEC-10 for coverage.

Priority: P0 2 P1 7 P2 7

Effort: S 6 M 7 L 3

☐ PII-1 P0 S Critical: Encryption Key Required but Not Enforced at Startup in Dev/Staging

PROBLEM The field-encryption key is required by code but not enforced at startup in dev/staging.

IMPACT Services can boot without encryption configured, risking plaintext writes.

FIX Assert FIELD_ENCRYPTION_KEY presence/validity at startup in all environments.

ACCEPTANCE Missing/invalid key prevents startup everywhere.

NOTES Config validation; key used by utils/encrypt (AES-256-GCM).

☐ PII-2 P0 M Critical: Broken Masking Function — Field Name Mismatches and Missing Decryption

PROBLEM The masking function is broken: field-name mismatches and missing decryption.

IMPACT Masked output is wrong/missing and some PII may not decrypt correctly.

FIX Fix field mappings and ensure encrypt/decrypt symmetry; add tests.

ACCEPTANCE Masking returns correct partials; encrypt → decrypt round-trips.

NOTES encrypt/mask utility; unit-test each PII field. Overlaps PII-10.

☐ PII-3 P1 M High: Bank Details (bankHolderName, bankName, bankIfsc) Stored Plaintext

PROBLEM Bank details (holder name, bank name, IFSC) are stored in plaintext.

IMPACT Sensitive financial PII is exposed at rest.

FIX Encrypt bank fields with the field-encryption scheme.

ACCEPTANCE Bank fields are ciphertext at rest; decrypt only when needed.

NOTES Seller bank model; AES-256-GCM. Pairs with COMP-17.

☐ PII-4 P1 M High: Location Data (lat/Ing) and Income (annualHouseholdIncome) Unencrypted

PROBLEM Location (lat/Ing) and household income are stored unencrypted.

IMPACT Sensitive personal data exposed at rest.

FIX Encrypt these fields at rest.

ACCEPTANCE Fields are ciphertext at rest.

NOTES User/farm profile model.

☐ PII-5 P1 M High: KYC Document URLs Likely Publicly Accessible (No Signed/Expiring URLs)

PROBLEM KYC document URLs are likely publicly accessible (no signed/expiring URLs).

IMPACT ID documents could be retrieved by anyone with the URL.

FIX Store KYC privately and serve via short-lived signed URLs with authz.

ACCEPTANCE KYC docs require a valid signed URL; public access fails.

NOTES Cloudinary access mode + signed delivery.

□ **PII-6** **P1** **L** **High: No Account Deletion / Right to Erasure Endpoint (DPDP Act §8)**

PROBLEM No account-deletion / right-to-erasure endpoint (DPDP Act §8).

IMPACT Non-compliance with erasure rights.

FIX Implement erasure across all stores with verification and audit.

ACCEPTANCE An erasure request removes/anonymizes the user's PII.

NOTES Same as COMP-4; cascade across DB/Cloudinary/AI.

□ **PII-7** **P1** **L** **High: No Consent Capture or Consent Proof Storage (DPDP Act §5)**

PROBLEM No consent capture or consent-proof storage (DPDP Act §5).

IMPACT Can't demonstrate lawful basis for processing.

FIX Capture versioned consent with timestamp/purpose and store proof.

ACCEPTANCE Consent records exist per user and purpose.

NOTES Consent service; gate role changes (AUTHZ-3).

□ **PII-8** **P1** **M** **High: No Data Retention Policy or Automated Cleanup**

PROBLEM No data-retention policy or automated cleanup.

IMPACT Indefinite retention conflicts with DPDP minimization.

FIX Define retention windows and automate purges/anonymization.

ACCEPTANCE Expired data is purged on schedule.

NOTES Implements COMP-16.

□ **PII-9** **P1** **S** **High: No Encryption for GST Number (Financial Identifier)**

PROBLEM The GST number (a financial identifier) isn't encrypted.

IMPACT Sensitive identifier exposed at rest.

FIX Encrypt the GST field at rest.

ACCEPTANCE GST stored as ciphertext.

NOTES Seller model; needed by invoicing (COMP-1).

□ **PII-10** **P2** **S** **Medium: Masking Functions in encrypt.js Are Defined but Never Used**

PROBLEM Masking functions in encrypt.js are defined but never used.

IMPACT PII may be logged/returned unmasked despite available helpers.

FIX Apply masking at all output/log points for PII.

ACCEPTANCE PII appears masked in responses/logs.

NOTES Wire masking into serializers/logger. Overlaps PII-2/CFG-5.

□ **PII-11** **P2** **M** **Medium: No Breach Notification Mechanism or Incident Log**

PROBLEM No breach-notification mechanism or incident log.

IMPACT Can't meet breach-notification duties or track incidents.

FIX Add an incident log and a defined breach-notification process.

ACCEPTANCE Incidents are logged; notification steps documented.

NOTES Security ops process + log store.

□ **PII-12** **P2** **L** **Medium: No Key Rotation Mechanism for FIELD_ENCRYPTION_KEY**

PROBLEM No key-rotation mechanism for FIELD_ENCRYPTION_KEY.

IMPACT A compromised key can't be rotated without manual pain; old data tied to one key.

FIX Support versioned keys and re-encryption to enable rotation.

ACCEPTANCE A key rotation re-encrypts data without downtime.

NOTES encrypt util; add key-id/versioning.

□ **PII-13** **P2** **M** **Medium: Children's Data Not Addressed (DPDP Act §9)**

PROBLEM Children's data isn't addressed (DPDP Act §9).

IMPACT Special protections for minors are unmet.

FIX Add age handling/consent rules per §9 where applicable.

ACCEPTANCE Minor-related flows follow §9 requirements.

NOTES Consent/age logic; consult legal.

□ **PII-14** **P2** **S** **Medium: Rate Limiting on PII Updates is Disabled**

PROBLEM Rate limiting on PII updates is disabled.

IMPACT PII fields can be churned/abused rapidly.

FIX Apply per-user limits on PII-update routes.

ACCEPTANCE Excess PII updates return 429.

NOTES Profile routes; same limiter as AUTH-3.

□ **PII-15** **P2** **S** **Low: AES-256-GCM Implementation is Correct, But IV Reuse Risk Not Documented**

PROBLEM AES-256-GCM is implemented correctly, but IV-reuse risk isn't documented/guarded.

IMPACT If an IV is ever reused with the same key, confidentiality breaks.

FIX Document IV uniqueness, generate IVs with a CSPRNG per encryption, and assert uniqueness.

ACCEPTANCE Each encryption uses a fresh random IV; guidance documented.

NOTES encrypt util; verify IV generation path.

□ **PII-16** **P2** **S** **Low: FastAPI PII Redaction Filter Works, But Not All PII Regex Patterns Comprehensive**

PROBLEM The FastAPI PII-redaction filter works but its regex set isn't comprehensive.

IMPACT Some PII types may slip into AI-service logs.

FIX Expand redaction patterns (phone/email/GST/IFSC/coords) and test.

ACCEPTANCE Sample PII of each type is redacted in logs.

NOTES AI-service logging filter.

Priority: P0 2 P1 4 P2 7

Effort: S 5 M 6 L 2

☐ SEC-1 P0 S Global Rate Limiting Disabled — DoS/Brute-Force Risk

PROBLEM Global rate limiting is disabled.

IMPACT DoS/brute-force exposure across the API.

FIX Enable a global limiter with per-route overrides.

ACCEPTANCE Over-cap traffic returns 429.

NOTES Same root as AUTH-2/OPS-2/CACHE-1/SCALE-7.

☐ SEC-2 P0 S OTP Dev Bypass Reachable in Production — Authentication Bypass

PROBLEM The OTP dev-bypass is reachable in production.

IMPACT An authentication bypass — anyone could skip OTP.

FIX Compile out / hard-gate the bypass so it can't run in production.

ACCEPTANCE The bypass path is unreachable in prod; verified by test.

NOTES OTP verify; environment guard. High-severity.

☐ SEC-3 P1 M Missing Input Validation on 7+ Routes — Injection/Query Bloat Risk

PROBLEM Input validation is missing on 7+ routes.

IMPACT Injection and query-bloat risk from unvalidated input.

FIX Add schema validation (types/lengths/enums) to the affected routes.

ACCEPTANCE Invalid payloads are rejected with 400 on those routes.

NOTES Express validators (zod/joi) per route.

☐ SEC-4 P1 M Error Message Leakage in 13+ Routes — Information Disclosure

PROBLEM Error messages leak internals on 13+ routes.

IMPACT Information disclosure aids attackers.

FIX Return generic client errors; log details server-side only.

ACCEPTANCE Client errors carry no stack/internal detail.

NOTES Central error handler; redaction (CFG-5).

☐ SEC-5 P1 M Payment Mock Mode Silent Failure — Payment Integrity Risk

PROBLEM Payment mock mode can fail silently — a payment-integrity risk.

IMPACT Mock fallback can mark orders paid without real payment.

FIX Disable mock in prod and surface errors loudly.

ACCEPTANCE No silent mock in prod; misconfig errors out.

NOTES Same as PAY-4/SHIP-11.

□ SEC-6 P1 M Missing Authorization Checks on Update/Delete — Privilege Escalation

PROBLEM Authorization checks are missing on some update/delete routes.

IMPACT Privilege escalation / unauthorized mutation.

FIX Add ownership/role checks to all mutating routes.

ACCEPTANCE Unauthorized update/delete returns 403.

NOTES Standardize an authz guard; overlaps AUTHZ-4.

□ SEC-7 P2 S No Max-Length Validation on Free-Text Fields — Memory/DoS Risk

PROBLEM No max-length validation on free-text fields.

IMPACT Oversized inputs risk memory/DoS and storage bloat.

FIX Enforce max lengths on free-text inputs.

ACCEPTANCE Over-length inputs are rejected.

NOTES Validators; pairs with SEC-3.

□ SEC-8 P2 M Hardcoded User-Supplied Data in Prisma Filters — ReDoS Risk

PROBLEM User-supplied data is hardcoded into Prisma filters — ReDoS risk.

IMPACT Crafted input can cause catastrophic regex/filter behavior.

FIX Sanitize/parameterize filter inputs and avoid user-built regex.

ACCEPTANCE Malicious filter inputs don't degrade performance.

NOTES Search/filter builders.

□ SEC-9 P2 M Missing UUID Validation on ID Parameters — Timing Attack / Enumeration Risk

PROBLEM ID parameters aren't validated as UUIDs.

IMPACT Enables enumeration/timing probing and malformed-id errors.

FIX Validate UUID format on id params before use.

ACCEPTANCE Non-UUID ids return 400.

NOTES Param validators; supports IDOR hardening.

□ SEC-10 P2 L Missing Audit Logging for Sensitive Operations — Compliance Risk

PROBLEM Sensitive operations lack audit logging.

IMPACT Compliance and forensic gaps.

FIX Emit audit events for sensitive operations.

ACCEPTANCE Sensitive actions are auditable.

NOTES Same as OPS-8; coordinate taxonomy.

□ SEC-11 P2 L No Fraud Detection or Brute-Force Protection — Account Takeover Risk

PROBLEM No fraud detection or brute-force protection — account-takeover risk.

IMPACT Credential attacks and fraud proceed unchecked.

FIX Add brute-force protection (lockout/limits) and risk signals.

ACCEPTANCE Brute-force attempts are blocked; risky logins flagged.

NOTES Combines AUTH-4/AUTH-14 with FRAUD-1/4.

□ SEC-12 P2 S Weak Phone Number Regex — UX Issue (Low Security Impact)

PROBLEM The phone-number regex is weak (UX issue, low security impact).

IMPACT Valid numbers may be rejected or vice versa.

FIX Use a robust phone validation (libphonenumber) shared across app.

ACCEPTANCE Valid Indian numbers pass; invalids rejected consistently.

NOTES Shared validator (FE-12).

□ SEC-13 P2 S CORS Preflight Not Cached — Chattiness (Low Priority)

PROBLEM CORS preflight isn't cached (chattiness, low priority).

IMPACT Extra preflight round-trips add latency.

FIX Set Access-Control-Max-Age to cache preflights.

ACCEPTANCE Preflights are cached for the configured duration.

NOTES CORS config.

Order Fulfillment & Logistics

SHIP

3PL, tracking, returns/RMA, serviceability.

13
TICKETS

Priority: P0 2 P1 5 P2 6

Effort: S 4 M 6 L 3

☐ SHIP-1 P0 L No Third-Party Logistics Integration

PROBLEM There is no third-party logistics (3PL) integration.

IMPACT Orders can't be shipped/tracked through a carrier — core fulfillment gap.

FIX Integrate a 3PL/aggregator for label creation, pickup, and tracking.

ACCEPTANCE An order can generate a shipment and receive tracking via the 3PL.

NOTES New shipping service; enables SHIP-2/SHIP-10.

☐ SHIP-2 P0 L Missing Shipment Tracking & Real-Time Updates

PROBLEM No shipment tracking or real-time status updates.

IMPACT Buyers/sellers can't see where an order is.

FIX Ingest carrier tracking events and expose status with updates.

ACCEPTANCE Order status reflects live tracking events.

NOTES Depends on SHIP-1; feeds SHIP-3 notifications.

☐ SHIP-3 P1 S No Buyer Notifications on Order Status Changes

PROBLEM Buyers aren't notified on order-status changes.

IMPACT Poor experience and more support load.

FIX Send notifications (push/SMS/email) on key status transitions.

ACCEPTANCE Status changes trigger buyer notifications.

NOTES Notification service; uses status from SHIP-2.

☐ SHIP-4 P1 M Refund Flow Is Incomplete (REFUNDED Status Unused)

PROBLEM The refund flow is incomplete — the REFUNDED status is unused.

IMPACT Refunds aren't reflected in order state.

FIX Wire REFUNDED into the order state machine on refund completion.

ACCEPTANCE A completed refund sets the order to REFUNDED.

NOTES Order state machine; ties to PAY-7.

☐ SHIP-5 P1 M No Delivery Charge Calculation or Serviceability Check

PROBLEM No delivery-charge calculation or serviceability check.

IMPACT Wrong/missing shipping fees and orders to unserviceable areas.

FIX Compute delivery charges and validate pincode serviceability at checkout.

ACCEPTANCE Checkout shows correct charges and blocks unserviceable pincodes.

NOTES Checkout + 3PL serviceability (SHIP-1/SHIP-8).

□ SHIP-6 P1 L Returns/RMA Workflow Completely Missing

PROBLEM The returns/RMA workflow is completely missing.

IMPACT No structured returns handling.

FIX Implement the RMA lifecycle (request → approve → return → inspect → resolve).

ACCEPTANCE A return is processed through the full RMA flow.

NOTES Same as COMP-8; integrates refunds (PAY-7).

□ SHIP-7 P1 M Seller Order Status Updates Bypass All External Validation

PROBLEM Seller order-status updates bypass all external validation.

IMPACT Sellers can set statuses inconsistent with carrier reality.

FIX Validate seller status changes against allowed transitions and carrier events.

ACCEPTANCE Invalid seller status changes are rejected.

NOTES Order state machine; reconcile with SHIP-2.

□ SHIP-8 P2 M Address Validation Is Minimal; No Reverse Geocoding or Serviceability

PROBLEM Address validation is minimal; no reverse geocoding or serviceability.

IMPACT Bad addresses cause failed deliveries.

FIX Validate/normalize addresses (geocode) and check serviceability.

ACCEPTANCE Invalid/unserviceable addresses are caught at entry.

NOTES Address service; pairs with SHIP-5.

□ SHIP-9 P2 M Inventory Stock Decrement Immediately; No Hold-and-Release Window

PROBLEM Inventory stock is decremented immediately with no hold-and-release window.

IMPACT Abandoned/failed orders can wrongly deplete stock.

FIX Reserve stock with a timed hold; commit on payment, release on failure/timeout.

ACCEPTANCE Unpaid/abandoned orders release reserved stock.

NOTES Inventory reservation; same as COMP-12.

□ SHIP-10 P2 S No Estimated Delivery Date or SLA Tracking

PROBLEM No estimated delivery date or SLA tracking.

IMPACT Buyers lack delivery expectations; no SLA accountability.

FIX Compute EDD and track delivery SLAs.

ACCEPTANCE Orders display EDD and SLA status.

NOTES Uses 3PL estimates (SHIP-1/SHIP-2).

□ SHIP-11 P2 S Mock Payment Mode Masks Integration Errors

PROBLEM Mock payment mode masks integration errors.

IMPACT Real integration bugs are hidden behind mock success.

FIX Disable mock in prod and test against real/sandbox gateway.

ACCEPTANCE Integration errors surface instead of being masked.

NOTES Same as PAY-4/SEC-5.

□ SHIP-12 P2 M Multi-Seller Order Scenarios Undertested

PROBLEM Multi-seller order scenarios are undertested.

IMPACT Split shipments/payouts/refunds may break for multi-seller carts.

FIX Add tests and handling for multi-seller order splitting.

ACCEPTANCE Multi-seller orders split, ship, and settle correctly in tests.

NOTES Order/settlement logic; pairs with COMP-2 payouts.

□ SHIP-13 P2 S No Bulk Order Actions or Batch Processing

PROBLEM No bulk order actions or batch processing.

IMPACT Sellers can't act on many orders efficiently.

FIX Add bulk actions (status update, label generation) with batching.

ACCEPTANCE Bulk actions process multiple orders in one operation.

NOTES Seller order tools; reuse job queue (SCALE-6).

Priority: P0 2 P1 5 P2 5

Effort: S 1 M 10 L 1

☐ OPS-1 P0 L No Dockerfile / containerization — deployment procedure unclear

PROBLEM There is no Dockerfile/containerization; deployment steps are unclear.

IMPACT Inconsistent, error-prone deploys and no reproducible runtime.

FIX Containerize each service with Dockerfiles and document the deploy procedure.

ACCEPTANCE Each service builds and runs from its image; deploy steps documented.

NOTES Add Dockerfiles + compose/orchestration; pairs with SCALE-3.

☐ OPS-2 P0 M Rate limiting disabled — no brute-force protection or DDoS mitigation

PROBLEM Rate limiting is disabled — no brute-force/DDoS mitigation.

IMPACT The platform is exposed to abuse and floods.

FIX Enable Redis-backed limiting across services with per-route policy.

ACCEPTANCE Floods are throttled with 429 in load test.

NOTES Same root as AUTH-2/SEC-1/CACHE-1.

☐ OPS-3 P1 M No centralized log aggregation or analysis

PROBLEM No centralized log aggregation or analysis.

IMPACT Debugging across services/instances is slow; no searchable history.

FIX Ship structured logs to a central store (ELK/Loki/cloud) with correlation ids.

ACCEPTANCE Logs from all services are searchable centrally with request ids.

NOTES Logging pipeline; correlation ties to SCALE-11 tracing.

☐ OPS-4 P1 M No monitoring, metrics, or alerting configured

PROBLEM No monitoring, metrics, or alerting configured.

IMPACT Incidents are detected late, by users.

FIX Add metrics (latency/error/saturation), dashboards, and alerts on SLOs.

ACCEPTANCE Key metrics dashboarded; alerts fire on threshold breaches.

NOTES Metrics endpoint + monitoring stack; consumes CACHE-9 etc.

☐ OPS-5 P1 S No uncaughtException handler for synchronous errors

PROBLEM No uncaughtException handler for synchronous errors.

IMPACT An uncaught sync error can crash the process unhandled.

FIX Add process-level handlers to log and gracefully shut down/restart.

ACCEPTANCE A simulated uncaught error is logged and handled cleanly.

NOTES Node bootstrap; add uncaughtException/unhandledRejection handlers.

☐ OPS-6 **P1** **M** Database migration procedure has no rollback or recovery documented

PROBLEM The DB migration procedure has no documented rollback/recovery.

IMPACT A bad migration has no defined recovery path.

FIX Document forward/rollback steps and test rollback in staging.

ACCEPTANCE A staging rollback succeeds per the runbook.

NOTES Prisma migrate workflow + runbook.

☐ OPS-7 **P1** **M** No documented backup, disaster recovery, or RTO/RPO targets

PROBLEM No documented backup, disaster recovery, or RTO/RPO targets.

IMPACT Data loss risk and undefined recovery expectations.

FIX Define backups, DR plan, and RTO/RPO; test a restore.

ACCEPTANCE A test restore meets the stated RTO/RPO.

NOTES DB backup automation + DR doc.

☐ OPS-8 **P2** **M** Audit logging coverage is incomplete

PROBLEM Audit-logging coverage is incomplete.

IMPACT Sensitive actions lack a reliable trail for compliance/forensics.

FIX Define an audit-event taxonomy and emit for all sensitive operations.

ACCEPTANCE All listed sensitive actions appear in the audit log.

NOTES Audit service; aligns with SEC-10/AUTH-18.

☐ OPS-9 **P2** **M** Frontend logger lacks context, breadcrumbs, and error tracking

PROBLEM The frontend logger lacks context, breadcrumbs, and error tracking.

IMPACT Frontend issues are hard to diagnose.

FIX Add structured logging with breadcrumbs and a crash-reporting integration.

ACCEPTANCE Frontend errors carry context and reach the tracker.

NOTES Frontend logging; pairs with FE-9.

☐ OPS-10 **P2** **M** No blue-green or canary deployment procedure documented

PROBLEM No blue-green/canary deployment procedure documented.

IMPACT Deploys are riskier with no safe rollout/rollback path.

FIX Define and document a canary or blue-green rollout strategy.

ACCEPTANCE A canary rollout + rollback is demonstrated.

NOTES CI/CD + orchestration (SCALE-3).

□ OPS-11 P2 M Test execution is not required in CI pipeline

PROBLEM Test execution is not required in CI.

IMPACT Untested code can merge/ship.

FIX Gate merges on passing tests (and lint/a11y where relevant).

ACCEPTANCE CI blocks merges when tests fail.

NOTES CI pipeline config; add a11y (COMP-15).

□ OPS-12 P2 M Secrets have no rotation policy or procedure

PROBLEM Secrets have no rotation policy or procedure.

IMPACT Stale/leaked secrets persist; slow revocation.

FIX Adopt a rotation schedule and revocation runbook.

ACCEPTANCE A scheduled rotation is executed via the runbook.

NOTES Same as CFG-6; coordinate with secret store (CFG-1).

Priority: P0 1 P1 4 P2 8

Effort: S 5 M 8 L 0

☐ CACHE-1 P0 M Rate Limiting Disabled — No Production DDoS/Abuse Protection

PROBLEM Rate limiting is disabled at the cache/Redis layer, so there is no shared throttling.

IMPACT No production DDoS/abuse protection across instances.

FIX Enable Redis-backed rate limiting shared by all instances with per-route policy.

ACCEPTANCE Limits enforced consistently across instances under load test.

NOTES Central limiter store; coordinate with AUTH-2/OPS-2/SEC-1.

☐ CACHE-2 P1 M Redis Optional Design May Hide Failures in Production

PROBLEM Redis is treated as optional; failures degrade silently instead of surfacing.

IMPACT Cache/limit/session features quietly stop working in production without alerts.

FIX Make Redis health explicit: alert on failure and fail safe for security-critical paths.

ACCEPTANCE A Redis outage raises an alert and security checks fail closed.

NOTES Redis client wrapper; add health metric (CACHE-9) and alerting (OPS-4).

☐ CACHE-3 P1 M No Cache Stampede Mitigation — Risk of Thundering Herd on Cache Expiry

PROBLEM No cache-stampede mitigation; many requests can recompute the same expired key at once.

IMPACT Thundering herd on expiry spikes DB load and latency.

FIX Add single-flight locking or stale-while-revalidate with jittered TTLs.

ACCEPTANCE Concurrent misses on a hot key trigger one recompute, not many.

NOTES Cache helper; lock per key in Redis.

☐ CACHE-4 P1 M No Session/Token Revocation via Redis — Logout Not Atomic Across Instances

PROBLEM No Redis-based session/token revocation; logout isn't atomic across instances.

IMPACT A logged-out token can remain valid on other instances.

FIX Maintain a revocation list/denylist in Redis checked by all instances.

ACCEPTANCE After logout, the token is rejected everywhere immediately.

NOTES Auth middleware checks denylist; ties to AUTH-6/AUTH-8.

☐ CACHE-5 P1 M Feature Flag Cache Invalidation Is In-Process Only — Not Broadcast to Other Instances

PROBLEM Feature-flag cache invalidation is in-process only and not broadcast to other instances.

IMPACT Flags can be inconsistent across instances after a change.

FIX Use Redis pub/sub (or a versioned key) to broadcast flag invalidations.

ACCEPTANCE Changing a flag updates all instances within seconds.

NOTES Feature-flag module; add pub/sub channel.

☐ **CACHE-6** **P2** **M** **No Cache Warming or Preloading for High-Traffic Data**

PROBLEM No cache warming/preloading for high-traffic data.

IMPACT Cold caches cause latency spikes after deploys/expiry.

FIX Warm key hot datasets on startup and on scheduled refresh.

ACCEPTANCE Hot keys are populated before first user request post-deploy.

NOTES Startup task + scheduled job (single-instance, see SCALE-2).

☐ **CACHE-7** **P2** **M** **No Caching for Product/Category/Agristore Listings — Repeated DB Queries**

PROBLEM Product/category/agristore listings aren't cached; each request re-queries the DB.

IMPACT Repeated identical queries waste DB capacity at scale.

FIX Cache listing responses with short TTL and targeted invalidation on writes.

ACCEPTANCE Repeat listing requests are served from cache; writes invalidate correctly.

NOTES Listing service; key by query params, invalidate on product mutation.

☐ **CACHE-8** **P2** **S** **MSP Rate Table Has No Automatic Expiry — Unbounded DB Growth**

PROBLEM The MSP rate table has no automatic expiry, growing unbounded in the DB.

IMPACT Storage grows indefinitely; stale rows accumulate.

FIX Add a retention/expiry policy and periodic cleanup for old MSP rows.

ACCEPTANCE Rows older than the retention window are pruned automatically.

NOTES MSP table + scheduled cleanup; align with COMP-16.

☐ **CACHE-9** **P2** **M** **No Metrics/Observability for Cache Hit Rates and Redis Memory Usage**

PROBLEM No metrics/observability for cache hit rate or Redis memory.

IMPACT Cache effectiveness and memory pressure are invisible.

FIX Export hit/miss counters and Redis memory metrics to monitoring.

ACCEPTANCE Dashboards show hit rate and memory; alerts on low hit rate / high memory.

NOTES Instrument cache helper; feed OPS-4 monitoring.

☐ **CACHE-10** **P2** **S** **Mandi Price Merge Logic Re-Runs on Every Request — No Result Caching**

PROBLEM Mandi-price merge logic re-runs on every request with no result caching.

IMPACT Repeated CPU work per request adds latency and load.

FIX Cache the merged result with a short TTL keyed by query.

ACCEPTANCE Identical mandi-price requests hit cache within the TTL.

NOTES Mandi-price service; memoize merged output in Redis.

☐ **CACHE-11** **P2** **S** **Redis Connection Retry Strategy May Retry Too Few Times — Silent Degradation**

PROBLEM The Redis connection retry strategy may give up too quickly, degrading silently.

IMPACT Transient blips drop Redis and disable dependent features without recovery.

FIX Use bounded exponential backoff with enough retries and surface persistent failure.

ACCEPTANCE Short outages auto-recover; sustained outage alerts.

NOTES Redis client config; pair with CACHE-2.

☐ **CACHE-12** **P2** **S** **No Cache Key Versioning — Schema Changes Risk Breaking All Cached Data**

PROBLEM Cache keys aren't versioned, so schema changes can serve incompatible cached data.

IMPACT Deploys with changed shapes can return broken cached payloads.

FIX Prefix keys with a schema/version tag and bump on shape changes.

ACCEPTANCE A version bump misses all old keys cleanly.

NOTES Cache key builder; add version constant.

☐ **CACHE-13** **P2** **S** **Weather Forecast Data Caching Treats Entire Response as One Unit**

PROBLEM Weather-forecast caching treats the entire response as one unit.

IMPACT Partial updates invalidate everything; coarse caching wastes refreshes.

FIX Cache by location/horizon granularity so parts can refresh independently.

ACCEPTANCE Updating one location doesn't invalidate all forecasts.

NOTES Weather service; restructure cache keys.

Priority: P0 1 P1 4 P2 7

Effort: S 6 M 6 L 0

☐ AISVC-1 **P0** **S** **CRITICAL: Unauthenticated /ai/chat and /ai/alerts endpoints enable unlimited free LLM abuse**

PROBLEM The /ai/chat and /ai/alerts endpoints accept requests with no authentication, so anyone who finds the URL can invoke the LLM.

IMPACT Unlimited free LLM calls drain the Groq spend cap, can run up real cost, and expose the service to abuse and scraping.

FIX Require the signed Express → FastAPI shared-secret header (HMAC + timestamp) on every AI route and reject unsigned calls with 401.

ACCEPTANCE Unauthenticated calls to /ai/chat and /ai/alerts return 401; a valid signed call from the gateway succeeds.

NOTES FastAPI dependency on the AI routers; reuse the AI_SHARED_SECRET verification used by other internal calls.

☐ AISVC-2 **P1** **S** **HIGH: GET /ai/scan/{job_id} lacks authorization — job results readable by anyone**

PROBLEM GET /ai/scan/{job_id} returns results to any caller without checking the requester owns that job.

IMPACT Job results (crop scans, possibly user images/diagnostics) are readable by anyone who guesses or enumerates a job id.

FIX Bind each job to its owning user/session and verify ownership before returning results; 403 on mismatch.

ACCEPTANCE A user can fetch only their own job ids; another user's id returns 403.

NOTES FastAPI scan router; persist owner_id with the job record and compare against the authenticated principal.

☐ AISVC-3 **P1** **M** **HIGH: No input validation for user text fields before LLM prompt injection**

PROBLEM User-supplied text fields are passed into the LLM prompt without validation or sanitization.

IMPACT Opens prompt-injection and jailbreak paths, and lets oversized inputs inflate token cost.

FIX Validate type/length, strip control characters, and template user text into a clearly delimited prompt section rather than concatenating.

ACCEPTANCE Inputs over the limit are rejected; injection probes in test fixtures do not alter system behavior.

NOTES Pydantic models on the request body; add max_length and a sanitizer before prompt assembly.

☐ AISVC-4 **P1** **S** **HIGH: API keys logged at startup without masking**

PROBLEM API keys are printed to logs at service startup without masking.

IMPACT Anyone with log access (or shipped logs) obtains live credentials — a direct secret leak.

FIX Never log full secrets; log only a masked suffix (e.g. ****1234) or omit entirely.

ACCEPTANCE Startup logs contain no full key; grep for the key value in logs returns nothing.

NOTES FastAPI startup/config load; route through a redaction filter.

□ AISVC-5 P1 M HIGH: Spend cap can be bypassed on free-tier Groq if costs are underestimated

PROBLEM	The spend cap relies on estimated per-call cost; if the estimate is low, real spend can exceed the cap on free-tier Groq.
IMPACT	Budget overruns go undetected until the bill or quota is blown.
FIX	Track actual token usage returned by the API, decrement the budget from real usage, and hard-stop at the cap.
ACCEPTANCE	Simulated runs that exceed the budget are blocked; ledger matches provider-reported usage.
NOTES	AI cost-accounting module; persist a running spend counter in Redis with atomic decrement.

□ AISVC-6 P2 M MEDIUM: GET /ai/scan/{job_id} exposed to enumeration and DoS via rate limit

PROBLEM	GET /ai/scan/{job_id} is reachable for enumeration and has no per-caller rate limit.
IMPACT	Allows id enumeration and DoS of the scan store.
FIX	Use non-sequential ids (UUID), add ownership checks (see AISVC-2), and apply a per-principal rate limit.
ACCEPTANCE	Sequential probing is infeasible and rate-limited; valid use unaffected.
NOTES	Pairs with AISVC-2; add slowapi/limiter to the route.

□ AISVC-7 P2 M MEDIUM: No schema validation on LLM output before storage and return

PROBLEM	LLM output is stored and returned without schema validation.
IMPACT	Malformed or unexpected model output can break downstream consumers or persist junk.
FIX	Validate model output against an expected schema; reject/repair before storage and return.
ACCEPTANCE	Outputs failing the schema are not stored and produce a safe error.
NOTES	Add a Pydantic response model and a parse step after the LLM call.

□ AISVC-8 P2 S MEDIUM: Health endpoint leaks internal version information without authentication

PROBLEM	The health endpoint returns internal version/build info without authentication.
IMPACT	Leaks fingerprinting data useful for targeting known-vulnerable versions.
FIX	Return a minimal public health payload; gate detailed/version info behind auth.
ACCEPTANCE	Public /health returns status only; version details require an authenticated call.
NOTES	FastAPI health route; split liveness from detailed diagnostics.

□ AISVC-9 P2 M MEDIUM: Redis connection failure degrades gracefully but spend cap becomes useless

PROBLEM	When Redis is down the service degrades gracefully but the spend cap (which lives in Redis) stops enforcing.
IMPACT	A Redis outage silently removes the cost ceiling, risking runaway spend.
FIX	Fail closed on the budget check when Redis is unavailable, or fall back to a conservative in-process cap.
ACCEPTANCE	With Redis unreachable, AI calls are blocked or hard-limited rather than uncapped.
NOTES	Wrap budget reads so a Redis error denies, not allows.

□ AISVC-10 P2 S **MEDIUM: CORS allow_origins read from environment at startup, no validation**

PROBLEM CORS allow_origins is read from the environment at startup with no validation of its contents.

IMPACT A misconfigured or wildcard origin can expose the AI service to untrusted web origins.

FIX Validate the origin list at boot (no `*`, well-formed URLs) and fail startup on bad config.

ACCEPTANCE Invalid origin config prevents startup; only configured origins are allowed at runtime.

NOTES FastAPI CORSMiddleware setup.

□ AISVC-11 P2 M **LOW: Timestamp skew window (60 seconds) is generous for signed requests**

PROBLEM Signed requests accept a 60-second timestamp skew window.

IMPACT A wide window lengthens the replay opportunity for captured signed requests.

FIX Tighten the skew (e.g. 10–15s) and add a short-lived nonce cache to block replays.

ACCEPTANCE Requests older than the window are rejected; replayed nonces are rejected.

NOTES Signature verification path shared with the Express gateway.

□ AISVC-12 P2 S **LOW: No request size limits on POST bodies**

PROBLEM POST bodies have no size limit.

IMPACT Large payloads can exhaust memory and inflate LLM token cost.

FIX Enforce a max request-body size and reject oversized bodies with 413.

ACCEPTANCE Bodies above the limit return 413; normal payloads pass.

NOTES Uvicorn/Starlette limits or a middleware guard.

Priority: P1 4 P2 9

Effort: S 6 M 7 L 0

☐ FE-1 P1 M SSL pinning defined but not enforced

PROBLEM SSL pinning is defined but not enforced in the mobile app.

IMPACT MITM interception of API traffic is possible on hostile networks.

FIX Enforce pinning against real certificate/public-key pins and fail closed.

ACCEPTANCE Requests to a mismatched cert are rejected on device.

NOTES React Native networking config; pairs with FE-4.

☐ FE-2 P1 M Farm profile and user preferences stored unencrypted in AsyncStorage

PROBLEM Farm profile and preferences are stored unencrypted in AsyncStorage.

IMPACT Local PII is readable on a compromised/rooted device.

FIX Use encrypted secure storage for sensitive local data.

ACCEPTANCE Sensitive values are not readable as plaintext on device.

NOTES Replace AsyncStorage with secure storage for PII.

☐ FE-3 P1 M Client-side cart total calculation without server revalidation

PROBLEM Cart total is calculated client-side without server revalidation.

IMPACT A tampered client can understate totals at checkout.

FIX Recompute and authorize totals server-side before payment.

ACCEPTANCE Server rejects client totals that don't match its computation.

NOTES Checkout API; authoritative pricing server-side (DS-5).

☐ FE-4 P1 M Placeholder SSL pins never replaced with actual certificate pins

PROBLEM Placeholder SSL pins were never replaced with real pins.

IMPACT Pinning is effectively inert.

FIX Insert real leaf/intermediate pins and a backup pin; test rotation.

ACCEPTANCE Pins match production certs; backup pin validated.

NOTES Completes FE-1.

☐ FE-5 P2 M Web platform token storage uses sessionStorage without encryption

PROBLEM Web token storage uses sessionStorage without encryption.

IMPACT Tokens exposed to XSS and inconsistent persistence.

FIX Adopt httpOnly secure cookies (or hardened storage) + CSP.

ACCEPTANCE Tokens absent from JS-readable storage.

NOTES Same direction as AUTH-9; needs COMP-14 CSP.

☐ **FE-6** **P2** **M** **No deep-linking security (app.json defines scheme but NavigationContainer has no linking config)**

PROBLEM Deep-linking has no security config (scheme declared in app.json but NavigationContainer has no linking config).

IMPACT Unvalidated deep links can drive unexpected navigation/state.

FIX Add a validated linking config and verify/whitelist link targets.

ACCEPTANCE Only whitelisted deep links resolve; others are rejected.

NOTES React Navigation linking config.

☐ **FE-7** **P2** **S** **No session timeout enforcement on client; relies solely on server 401 response**

PROBLEM No client session-timeout enforcement; relies solely on server 401.

IMPACT Stale sessions linger client-side until a failed call.

FIX Track inactivity client-side and proactively log out / refresh.

ACCEPTANCE Idle past the timeout triggers client logout.

NOTES Client auth context; complements AUTH-16.

☐ **FE-8** **P2** **S** **Socket.io token validation only server-side; no client-side expiry check**

PROBLEM Socket.IO token validation is server-side only; no client-side expiry check.

IMPACT Client may hold a dead socket auth until rejected.

FIX Check token expiry client-side and re-auth/reconnect proactively.

ACCEPTANCE Client refreshes/reconnects before using an expired token.

NOTES Socket client wrapper.

☐ **FE-9** **P2** **S** **Error boundary logs to console in dev but no crash reporting integration**

PROBLEM The error boundary logs to console in dev but has no crash-reporting integration.

IMPACT Production crashes are invisible to the team.

FIX Integrate crash/error reporting (e.g. Sentry) from the boundary.

ACCEPTANCE Unhandled errors appear in the reporting tool with context.

NOTES Error boundary; ties to OPS-9 frontend logging.

☐ **FE-10** **P2** **S** **No rate limiting on client; OTP spam not prevented locally**

PROBLEM No client-side rate limiting; OTP spam isn't curbed locally.

IMPACT Users can hammer OTP send before server limits respond.

FIX Add client cooldowns/disable on the OTP button.

ACCEPTANCE OTP resend is locked during cooldown.

NOTES Client OTP screen; server limits remain authoritative (AUTH-1).

□ FE-11 P2 S No input sanitization on frontend; reliant on backend stripHtml

PROBLEM No frontend input sanitization; relies entirely on backend stripHtml.

IMPACT Risky if any path renders unsanitized input.

FIX Add defense-in-depth client sanitization/escaping on rendered user content.

ACCEPTANCE User content renders escaped; injection probes don't execute.

NOTES Shared sanitize util; backend remains source of truth.

□ FE-12 P2 S Form validation logic not centralized; phone/pincode regex duplicated

PROBLEM Form-validation logic isn't centralized; phone/pincode regex is duplicated.

IMPACT Drift between copies causes inconsistent validation.

FIX Extract shared validators used across forms.

ACCEPTANCE All forms use one validator; tests cover it.

NOTES Shared validation module.

□ FE-13 P2 M No proof-of-work or CAPTCHA for OTP send to prevent account enumeration

PROBLEM No proof-of-work/CAPTCHA on OTP send to deter enumeration.

IMPACT Automated enumeration/abuse of OTP send is cheap.

FIX Add CAPTCHA or PoW gate before OTP send under suspicion.

ACCEPTANCE Automated bulk OTP sends are blocked by the challenge.

NOTES Pairs with AUTH-1 server limits and FE-10.

Priority: P1 3 P2 9

Effort: S 6 M 5 L 1

☐ DB-1 P1 M N+1 in Checkout Transaction (Stock Validation Loop)

PROBLEM Checkout validates stock in a loop, issuing a query per line item (N+1).

IMPACT Checkout latency grows with cart size and strains the DB under load.

FIX Batch-fetch stock for all items in one query and validate in memory.

ACCEPTANCE Checkout issues a constant number of stock queries regardless of cart size.

NOTES Checkout service; single Prisma findMany with `in` on product ids. Overlaps DS-1.

☐ DB-2 P1 M Missing Connection Pool Configuration for 1000-User Scale

PROBLEM Connection pool isn't configured for the 1000-user target.

IMPACT Default pool can exhaust under concurrency, causing timeouts.

FIX Tune Prisma/pg pool size and timeouts to expected concurrency.

ACCEPTANCE Load test at target concurrency shows no pool exhaustion.

NOTES Prisma datasource/pool settings; overlaps SCALE-4.

☐ DB-3 P1 S Unbounded Chat Query Without Limit

PROBLEM A chat query runs without a LIMIT.

IMPACT Large threads return unbounded rows, spiking memory/latency.

FIX Paginate/limit chat queries with sensible defaults.

ACCEPTANCE Chat fetch returns a bounded page size.

NOTES Chat repository; add take/cursor.

☐ DB-4 P2 S Unbounded MandiPrice Query (No Date-Range Prefilter)

PROBLEM MandiPrice queries run without a date-range prefilter.

IMPACT Full-range scans get slower as the table grows.

FIX Require/apply a default date window and index it.

ACCEPTANCE Queries are bounded by date and use the index.

NOTES Mandi-price repo; composite index with date (DS-3).

☐ DB-5 P2 S Missing Composite Indexes on Frequently Sorted Queries

PROBLEM Frequently sorted queries lack composite indexes.

IMPACT Sorts/filters fall back to scans at scale.

FIX Add composite indexes matching common filter+sort patterns.

ACCEPTANCE EXPLAIN shows index use on the targeted queries.

NOTES prisma schema @@index; verify with query plans.

DB-6 P2 M Offset-Based Pagination Will Degrade at Scale

PROBLEM Pagination is offset-based.

IMPACT Deep pages get progressively slower.

FIX Move hot lists to keyset/cursor pagination.

ACCEPTANCE Deep-page latency stays flat in load test.

NOTES List repositories; cursor on indexed column. Overlaps DB-12.

DB-7 P2 M Float Used for Financial Amounts (Rounding Risk)

PROBLEM Financial amounts use float in the DB.

IMPACT Rounding errors corrupt money math.

FIX Store money as integer minor units or Decimal.

ACCEPTANCE No rounding drift across compute/store/round-trip.

NOTES Schema migration; overlaps PAY-8.

DB-8 P2 M Full-Text Search Using ILIKE Will Slow at Scale

PROBLEM Full-text search uses ILIKE.

IMPACT Leading-wildcard ILIKE can't use indexes and slows at scale.

FIX Adopt Postgres full-text (tsvector/GIN) or trigram indexes.

ACCEPTANCE Search latency stays acceptable on large datasets via index.

NOTES Search queries; add GIN index + query rewrite.

DB-9 P2 S Missing Index: Review[userId] for Buyer Profile Review History

PROBLEM Missing index on Review[userId] for buyer review history.

IMPACT Profile review lookups scan the table.

FIX Add an index on Review.userId.

ACCEPTANCE Review-by-user queries use the index.

NOTES prisma schema @@index([userId]).

DB-10 P2 S Missing Index: Notification[userId + createdAt] for Efficient Unread Queries

PROBLEM Missing composite index Notification[userId, createdAt] for unread queries.

IMPACT Unread/recent notification queries are inefficient.

FIX Add the composite index.

ACCEPTANCE Unread queries use the index in EXPLAIN.

NOTES prisma schema @@index([userId, createdAt]).

□ **DB-11** **P2** **L** **Geo Query Without Bounding-Box Index on MachineryListing**

PROBLEM Geo queries on MachineryListing run without a bounding-box/spatial index.

IMPACT Nearby-machinery searches scan and sort large sets.

FIX Add a bounding-box prefilter and spatial index (PostGIS or lat/lng range index).

ACCEPTANCE Geo search uses the index and avoids full scans.

NOTES Overlaps DS-7; consider PostGIS.

□ **DB-12** **P2** **S** **Complex Search Query May Not Use Optimal Index Path**

PROBLEM A complex search query may not use the optimal index path.

IMPACT Suboptimal plans add latency.

FIX Review EXPLAIN and add/adjust indexes or rewrite the query.

ACCEPTANCE Targeted query uses the intended index.

NOTES Pairs with DB-5/DB-6.

REV

Reviews & Moderation

Verified purchase, moderation, spam & abuse.

12
TICKETS

Priority: P1 6 P2 6

Effort: S 3 M 8 L 1

REV-1 P1 M No Verified-Purchase Gating on Reviews

PROBLEM Reviews aren't gated to verified purchases.

IMPACT Anyone can post reviews, enabling fake ratings.

FIX Require a verified purchase/order link to review a product/seller.

ACCEPTANCE Only verified buyers can review the relevant item.

NOTES Review create path checks order history.

REV-2 P1 M HTML Sanitization Only — No Profanity, Spam, or Toxicity Filtering

PROBLEM Only HTML sanitization exists — no profanity/spam/toxicity filtering.

IMPACT Abusive or spammy content passes through.

FIX Add content filtering (profanity/spam/toxicity) before publish or queue for review.

ACCEPTANCE Flagged content is blocked or queued.

NOTES Moderation pipeline; can reuse AI service.

REV-3 P1 M No Image Moderation or NSFW/Explicit Content Checks

PROBLEM No image moderation or NSFW/explicit checks on uploads.

IMPACT Explicit/abusive images can be posted.

FIX Run image moderation on uploads and block/queue violations.

ACCEPTANCE NSFW test images are blocked/queued.

NOTES Upload pipeline (Cloudinary) + moderation.

REV-4 P1 M No User Report/Flag Mechanism for Abuse

PROBLEM No user report/flag mechanism for abuse.

IMPACT Users can't report bad content; moderation is blind.

FIX Add report/flag endpoints feeding the moderation queue.

ACCEPTANCE Reported items appear in the queue with reason.

NOTES Feeds REV-5 queue.

REV-5 P1 L No Admin Review Moderation Queue or Dashboard

PROBLEM No admin review-moderation queue or dashboard.

IMPACT No place to triage flagged content.

FIX Build a moderation queue with actions (approve/remove/ban).

ACCEPTANCE Admins action flagged items from the queue.

NOTES Part of admin console (COMP-7); needs AUTH-10.

□ REV-6 P1 M Review Spam and Fake Account Attack Surface

PROBLEM Review spam and fake-account attack surface is unaddressed.

IMPACT Coordinated fake reviews degrade trust.

FIX Add rate limits, verified-purchase gating, and fake-account signals.

ACCEPTANCE Spam bursts are throttled and flagged.

NOTES Combines REV-1/REV-11 with FRAUD-5.

□ REV-7 P2 S Denormalized Rating Fields Can Fall Out of Sync

PROBLEM Denormalized rating fields can fall out of sync with source reviews.

IMPACT Displayed averages/counts become inaccurate.

FIX Recompute via transaction/trigger or scheduled reconciliation.

ACCEPTANCE Aggregates match underlying reviews after writes.

NOTES Rating update path; transactional recompute.

□ REV-8 P2 M No Listing Ownership Verification or Verification Workflow

PROBLEM No listing-ownership verification or verification workflow.

IMPACT Listings may be created/edited by non-owners or unverified sellers.

FIX Verify ownership on listing mutations and add a seller-verification step.

ACCEPTANCE Only verified owners can manage their listings.

NOTES Listing routes + seller verification (KYC).

□ REV-9 P2 M Comments and Messages Have No Edit or Soft-Delete

PROBLEM Comments and messages have no edit or soft-delete.

IMPACT Users can't correct/remove content; no moderation removal trail.

FIX Add edit and soft-delete with audit.

ACCEPTANCE Edit/soft-delete work and are logged.

NOTES Overlaps REV-12/AUTHZ-7.

□ REV-10 P2 S No Seller Response or Rebuttal Mechanism for Negative Reviews

PROBLEM No seller response/rebuttal mechanism for negative reviews.

IMPACT Sellers can't address unfair reviews.

FIX Allow a single seller response per review.

ACCEPTANCE Sellers can post one visible response.

NOTES Review schema + UI.

□ REV-11 P2 S No Rate Limiting on Review/Comment/Message Creation Endpoints

PROBLEM No rate limiting on review/comment/message creation.

IMPACT Spam flooding of UGC endpoints.

FIX Apply per-user creation limits on these endpoints.

ACCEPTANCE Bursts beyond the cap return 429.

NOTES Shared limiter; supports REV-6.

□ REV-12 P2 M Community Posts and Comments Have No Visibility Flags or Soft-Delete

PROBLEM Community posts/comments have no visibility flags or soft-delete.

IMPACT No way to hide/remove content while keeping a trail.

FIX Add visibility/soft-delete fields and enforce in queries.

ACCEPTANCE Hidden/deleted items are excluded from public views but retained.

NOTES Community schema; pairs with AUTHZ-2/REV-9.

Scalability & System Design

SCALE

Multi-process, queues, circuit breakers, sockets.

11

TICKETS

Priority: **P1** 3 **P2** 8

Effort: **S** 4 **M** 5 **L** 2

☐ SCALE-1 **P1** **M** Unbounded In-Memory Maps Will Cause Memory Leak Under Load

PROBLEM Unbounded in-memory maps grow without eviction under load.

IMPACT Memory leaks lead to OOM/restarts at scale.

FIX Bound these structures (LRU/TTL) or move state to Redis.

ACCEPTANCE Memory stays bounded under sustained load.

NOTES Audit in-memory caches/trackers; replace with bounded store.

☐ SCALE-2 **P1** **M** Cron Jobs and Intervals Execute on Every Instance in Multi-Process Deployments

PROBLEM Cron jobs/intervals run on every instance in multi-process deployments.

IMPACT Duplicate executions cause double work and data races.

FIX Elect a single runner (lock/leader) or use a dedicated scheduler.

ACCEPTANCE Each scheduled job runs once per tick across the fleet.

NOTES Redis lock or external scheduler; affects CACHE-6/COMP-16 jobs.

☐ SCALE-3 **P1** **L** Deployment Strategy Undefined — No Orchestration or Scaling Scripts

PROBLEM Deployment strategy is undefined — no orchestration or scaling scripts.

IMPACT Can't scale horizontally or deploy reproducibly.

FIX Define orchestration (compose/k8s) with scaling and rollout scripts.

ACCEPTANCE Services scale via documented orchestration.

NOTES Builds on OPS-1 containers; enables OPS-10.

☐ SCALE-4 **P2** **S** No Prisma Database Connection Pool Configuration (Uses Hardcoded Defaults)

PROBLEM No Prisma DB connection-pool configuration (hardcoded defaults).

IMPACT Pool exhaustion under concurrency.

FIX Configure pool size/timeouts for target load.

ACCEPTANCE No pool exhaustion at target concurrency.

NOTES Same as DB-2.

☐ SCALE-5 **P2** **M** Socket.IO Broadcast Not Protected Against Burst Message Floods

PROBLEM Socket.IO broadcasts aren't protected against burst message floods.

IMPACT A flood can overwhelm broadcast fan-out and clients.

FIX Throttle/debounce broadcasts and rate-limit emitters.

ACCEPTANCE Burst emitters are throttled; broadcast stays stable.

NOTES Socket layer; per-connection limits (SCALE-9).

□ **SCALE-6** **P2** **L** **No Request Queue System — Heavy Operations Block Event Loop**

PROBLEM No request-queue system; heavy operations block the event loop.

IMPACT Long tasks stall request handling and hurt latency.

FIX Offload heavy work to a job queue/worker.

ACCEPTANCE Heavy operations run async without blocking requests.

NOTES Introduce a queue (BullMQ/Redis) + workers.

□ **SCALE-7** **P2** **S** **Rate Limiting Disabled in Production**

PROBLEM Rate limiting is disabled in production.

IMPACT No abuse/flood protection in prod.

FIX Enable production limiting across services.

ACCEPTANCE Prod enforces limits under test.

NOTES Same family as AUTH-2/OPS-2/SEC-1/CACHE-1.

□ **SCALE-8** **P2** **M** **No Circuit Breaker Pattern for External API Calls**

PROBLEM No circuit-breaker pattern for external API calls.

IMPACT A failing dependency can cascade and exhaust resources.

FIX Wrap external calls in circuit breakers with timeouts/fallbacks.

ACCEPTANCE A failing dependency trips the breaker and recovers.

NOTES External clients (Razorpay/Cloudinary/IMD/AI).

□ **SCALE-9** **P2** **S** **Socket.IO Connection Tracking Not Limited — Could Leak Sockets**

PROBLEM Socket.IO connection tracking isn't limited — sockets could leak.

IMPACT Unbounded connections/handles exhaust resources.

FIX Cap connections per user/IP and clean up on disconnect.

ACCEPTANCE Connection counts stay bounded; no handle leak.

NOTES Socket lifecycle; pairs with SCALE-5.

□ **SCALE-10** **P2** **S** **FastAPI Uvicorn Running in Single-Process Reload Mode (Dev Config in Code)**

PROBLEM FastAPI Uvicorn runs in single-process reload mode (a dev config) in code.

IMPACT Dev settings in production limit throughput and stability.

FIX Run multiple workers without reload for production (gunicorn/uvicorn workers).

ACCEPTANCE Production runs multi-worker, no reload.

NOTES AI-service launch config.

□ **SCALE-11** **P2** **M** **No Distributed Tracing or Observability for Request Paths Across Services**

PROBLEM No distributed tracing/observability across service request paths.

IMPACT Cross-service latency/errors are hard to attribute.

FIX Add tracing with propagated correlation ids (OpenTelemetry).

ACCEPTANCE A request is traceable across Express ↔ FastAPI.

NOTES Tracing SDK; complements OPS-3 logging.

Data Structures & Algorithms

DS

Algorithmic efficiency & in-memory vs DB work.

10

TICKETS

Priority: P1 3 P2 7

Effort: S 5 M 5 L 0

☐ DS-1 P1 M Sequential database updates in checkout loop— $O(n)$ database round-trips

- PROBLEM** Checkout updates stock with sequential per-item DB writes ($O(n)$ round-trips).
- IMPACT** Write latency scales with cart size; transaction holds longer.
- FIX** Batch the updates (single statement / batched transaction).
- ACCEPTANCE** Stock updates use a constant number of statements per checkout.
- NOTES** Checkout service; Prisma \$transaction with batched updates. Overlaps DB-1.

☐ DS-2 P1 M In-memory filtering of mandi price data instead of delegating to DB query

- PROBLEM** Mandi-price data is filtered in memory instead of in the DB query.
- IMPACT** Over-fetches rows then discards them, wasting IO/CPU.
- FIX** Push filters into the SQL/Prisma where-clause.
- ACCEPTANCE** Only matching rows are fetched.
- NOTES** Mandi-price service; move predicates to query. Needs DS-3 index.

☐ DS-3 P1 S No indices evident on mandiPrice table for commodity+state+district queries

- PROBLEM** No indices on mandiPrice for commodity+state+district queries.
- IMPACT** These lookups scan the table.
- FIX** Add a composite index on (commodity, state, district[, date]).
- ACCEPTANCE** Lookups use the index.
- NOTES** prisma schema; pairs with DB-4.

☐ DS-4 P2 S $O(n)$ lookup in getCityId() via Object.entries().find() on every IMD scrape request

- PROBLEM** getCityId() does an $O(n)$ Object.entries().find() on every IMD scrape.
- IMPACT** Linear lookup per request wastes CPU and slows scraping.
- FIX** Build a one-time Map (name → id) and do $O(1)$ lookups.
- ACCEPTANCE** City lookup is constant-time.
- NOTES** IMD scraper util; memoize the map at module load.

☐ DS-5 P2 M Cart total computation via in-memory loop instead of SQL SUM()

- PROBLEM** Cart total is computed via an in-memory loop instead of SQL SUM().
- IMPACT** Extra data transfer and CPU for a value the DB can aggregate.
- FIX** Compute totals with an aggregate query where appropriate.
- ACCEPTANCE** Totals come from a single aggregate.
- NOTES** Cart/checkout; Prisma aggregate. Note server-side revalidation (FE-3).

□ **DS-6** **P2** **S** **District → mandi name lookup via Object.entries() iteration on every /nearby call**

PROBLEM District → mandi-name lookup iterates Object.entries() on every /nearby call.

IMPACT Repeated linear scans per request.

FIX Precompute a lookup map once and reuse.

ACCEPTANCE Lookup is constant-time per request.

NOTES Nearby handler; build map at startup.

□ **DS-7** **P2** **M** **Rent/machinery geo-queries use 500-record memory buffer even when paginating later**

PROBLEM Rent/machinery geo-queries buffer 500 records in memory even when paginating later.

IMPACT Wasted memory/CPU fetching rows that pagination discards.

FIX Apply geo + pagination in the query so only needed rows load.

ACCEPTANCE Memory use is bounded by page size, not 500.

NOTES Overlaps DB-11; push bounding-box + limit to SQL.

□ **DS-8** **P2** **M** **No pre-computed aggregations for common dashboard queries**

PROBLEM No pre-computed aggregations for common dashboard queries.

IMPACT Dashboards recompute heavy aggregates on each load.

FIX Maintain materialized/cached aggregates refreshed periodically.

ACCEPTANCE Dashboard reads hit precomputed aggregates.

NOTES Materialized views or cached rollups (CACHE-6).

□ **DS-9** **P2** **S** **Market data service does not cache commodity-level PRICE_CONTEXT appropriately**

PROBLEM Market-data service doesn't cache commodity-level PRICE_CONTEXT appropriately.

IMPACT Recomputes/refetches context repeatedly.

FIX Cache per-commodity context with suitable TTL.

ACCEPTANCE Repeat lookups within TTL are served from cache.

NOTES Market-data service; Redis keyed by commodity. Overlaps CACHE-10.

□ **DS-10** **P2** **S** **String case-sensitivity in filtering despite case-insensitive DB queries**

PROBLEM Filtering applies case-sensitive string compares though DB queries are case-insensitive.

IMPACT Inconsistent matching between layers causes missed results.

FIX Normalize case consistently (fold both sides) in app-side filtering.

ACCEPTANCE App and DB filtering return consistent matches.

NOTES Shared filter util; lowercase-compare.

Priority: P1 1 P2 6

Effort: S 4 M 3 L 0

☐ AUTHZ-1 P1 S Missing Authorization on POST /ai/scan/:sessionId/chat

PROBLEM POST /ai/scan/:sessionId/chat has no authorization check tying the caller to the session.

IMPACT A user can post into another user's scan session (IDOR).

FIX Verify the authenticated user owns sessionId before accepting the message.

ACCEPTANCE Posting to a session you don't own returns 403.

NOTES Express AI proxy route; ownership lookup before forwarding.

☐ AUTHZ-2 P2 S No DELETE endpoint for community posts

PROBLEM There is no DELETE endpoint for community posts.

IMPACT Users/moderators cannot remove their own or abusive posts.

FIX Add a delete (soft-delete preferred) with ownership/moderator checks.

ACCEPTANCE Owners and moderators can delete; others get 403.

NOTES Community router; pairs with REV-12 soft-delete.

☐ AUTHZ-3 P2 M Automatic FARMER → SELLER role promotion without user consent

PROBLEM FARMER accounts are auto-promoted to SELLER without explicit user consent.

IMPACT Silent role escalation may grant capabilities and obligations the user didn't accept.

FIX Require an explicit opt-in/seller-onboarding step before granting SELLER.

ACCEPTANCE Role changes only after recorded user consent.

NOTES Role-assignment logic; capture consent (ties to PII-7).

☐ AUTHZ-4 P2 M Missing authorization verification on some rental booking endpoints

PROBLEM Some rental-booking endpoints don't verify the caller is authorized for the resource.

IMPACT Possible IDOR on bookings (view/modify others' rentals).

FIX Add owner/role checks on every rental mutation and read of a specific booking.

ACCEPTANCE Accessing another user's booking returns 403.

NOTES Rental/machinery router; standardize an ownership guard.

☐ AUTHZ-5 P2 S Potential unsafe parent comment selection in POST /community/posts/:id/comments

PROBLEM Parent-comment selection in POST /community/posts/:id/comments may attach to an unrelated parent.

IMPACT Comments can be grafted onto the wrong post/thread.

FIX Validate that parentId belongs to the same post before inserting.

ACCEPTANCE A parentId from another post is rejected.

NOTES Community comments handler; add a relationship check.

□ AUTHZ-6 P2 S Insufficient IDOR verification matrix on cropReportShare routes

PROBLEM cropReportShare routes have an incomplete IDOR verification matrix.

IMPACT Shared crop reports may be accessible to users outside the intended share.

FIX Define and enforce who-can-do-what for each share route (owner, sharee, public).

ACCEPTANCE Each route enforces the documented access matrix; out-of-scope access is denied.

NOTES cropReportShare router; write the matrix, then test each cell.

□ AUTHZ-7 P2 M No soft-delete audit trail on archived resources

PROBLEM Archived/soft-deleted resources have no audit trail.

IMPACT No record of who archived what, hampering dispute resolution and compliance.

FIX Log archive/restore actions with actor and timestamp.

ACCEPTANCE Archive/restore events are queryable in the audit log.

NOTES Shared soft-delete utility + audit hook.

Priority: P1 3 P2 4

Effort: S 3 M 3 L 1

☐ CFG-1 P1 M Live API Keys Committed in Local .env Files (Non-Git but Filesystem Risk)

PROBLEM Live API keys are committed in local .env files (not in git, but present on developer filesystems).

IMPACT Secrets spread across machines increase leak surface and complicate rotation.

FIX Move secrets to a managed secret store/vault; keep only references locally; rotate exposed keys.

ACCEPTANCE No live secrets in repo or shared .env; app reads from the secret store.

NOTES Config loader; document in CFG-6 rotation procedure.

☐ CFG-2 P1 S AI_SHARED_SECRET Between Express and FastAPI Not Enforced in Production

PROBLEM AI_SHARED_SECRET between Express and FastAPI isn't enforced in production config.

IMPACT The internal trust boundary can be bypassed if the secret is absent.

FIX Require the secret at boot in production and fail startup if missing.

ACCEPTANCE Production refuses to start without the shared secret; signed calls verified.

NOTES Both services' startup validation; ties to AISVC-1.

☐ CFG-3 P1 S RAZORPAY_KEY_ID and RAZORPAY_KEY_SECRET Not Validated for Production Use

PROBLEM RAZORPAY_KEY_ID/SECRET aren't validated for production use (test vs live not enforced).

IMPACT Risk of running live traffic on test keys or vice versa.

FIX Validate key mode at startup and assert live keys in production.

ACCEPTANCE Production boot fails on test keys; mode logged (masked).

NOTES Payment config validation; pair with PAY-4 mock-mode guard.

☐ CFG-4 P2 S Default Empty-String Fallbacks Weaken AI Service Resilience

PROBLEM Empty-string fallbacks for config weaken AI-service resilience (silently 'works' misconfigured).

IMPACT Misconfiguration is masked, producing subtle runtime failures.

FIX Replace silent defaults with explicit required-config checks.

ACCEPTANCE Missing required config fails fast with a clear error.

NOTES FastAPI settings; remove empty defaults.

☐ CFG-5 P2 M No Secret Masking in Logs or Error Messages

PROBLEM Secrets can appear unmasked in logs or error messages.

IMPACT Accidental secret disclosure via logs/stack traces.

FIX Centralize a redaction filter applied to all logs and error serializers.

ACCEPTANCE Known secret patterns never appear in logs.

NOTES Logger middleware; covers AISVC-4 too.

□ **CFG-6** **P2** **M** **No Documented Secret Rotation or Emergency Revocation Procedure**

PROBLEM No documented secret rotation or emergency revocation procedure.

IMPACT Slow, error-prone response to a leak.

FIX Write and test a rotation/revocation runbook for each secret type.

ACCEPTANCE A dry-run rotation completes using the runbook.

NOTES Ops docs; align with OPS-12/CFG-1.

□ **CFG-7** **P2** **L** **Cloudinary Credentials Held in Memory Without Refresh or Expiry**

PROBLEM Cloudinary credentials are held in memory with no refresh/expiry handling.

IMPACT Stale credentials cause failures; no rotation path at runtime.

FIX Support credential refresh and graceful re-auth without restart.

ACCEPTANCE Rotating Cloudinary creds doesn't require a redeploy.

NOTES Storage client init; read from secret store (CFG-1).

FRAUD

Fraud Detection

Velocity, device fingerprinting, abuse signals.

6

TICKETS

Priority: P1 3 P2 3

Effort: S 1 M 5 L 0

☐ FRAUD-1 P1 M Velocity limits

PROBLEM No velocity limits on sensitive actions (orders, refunds, logins).

IMPACT High-velocity fraud proceeds unchecked.

FIX Define per-user/device/IP velocity thresholds feeding risk decisions.

ACCEPTANCE Actions above thresholds are flagged/limited.

NOTES Risk service; overlaps COMP-10.

☐ FRAUD-2 P1 M Refund / chargeback abuse

PROBLEM No refund/chargeback abuse handling.

IMPACT Serial abusers cause repeated loss.

FIX Detect abnormal refund/chargeback rates and restrict offenders.

ACCEPTANCE Repeat-abuse accounts are flagged and limited.

NOTES Implements COMP-5; needs payment history.

☐ FRAUD-3 P1 M Device fingerprinting & multi-account detection

PROBLEM No device fingerprinting or multi-account detection.

IMPACT One actor can run many accounts undetected.

FIX Add device fingerprinting and link likely-related accounts for review.

ACCEPTANCE Linked multi-accounts surface to review.

NOTES Overlaps COMP-10; fingerprint at login/order.

☐ FRAUD-4 P2 M Geo-anomaly login detection

PROBLEM No geo-anomaly login detection.

IMPACT Impossible-travel/anomalous logins aren't caught.

FIX Score logins on geo/IP anomalies and step-up or alert.

ACCEPTANCE Anomalous logins trigger step-up/alert.

NOTES Login pipeline; uses auth audit (AUTH-18).

☐ FRAUD-5 P2 M Fake-review & fake-listing signals

PROBLEM No fake-review/fake-listing signals.

IMPACT Fake content erodes marketplace trust.

FIX Add heuristics (burst, duplication, account age) to flag suspicious reviews/listings.

ACCEPTANCE Suspicious items route to moderation.

NOTES Overlaps REV-6; feeds admin queue (REV-5).

□ **FRAUD-6** **P2** **S** **Payment-amount tamper alarms**

PROBLEM	No payment-amount tamper alarms.
IMPACT	Mismatched client/server amounts may go unnoticed.
FIX	Alert when confirmed amount differs from order amount.
ACCEPTANCE	Any mismatch raises an alert and blocks confirmation.
NOTES	Pairs with PAY-3 amount verification and FE-3.